

cs-mail: Express Lanes for Transactional Mail

A Pedagogical Memo

C-SQD

Draft 0.1 — August 2026

Nonnormative memo. This document explains a concept and motivates it for a reader new to the underlying ideas. It introduces *express lanes*, the user-facing form of the scoped capabilities described in the *cs-mail Protocol Specification*. The settlement and privacy semantics remain governed by that specification; the issuance, safety, and lifetime rules sketched here will be defined normatively in a later document.

1 A First Week with a New Bank Account

You opened a checking account on Monday. By Friday your inbox holds a welcome note from `welcome@bank.com`, a statement notice from `statements@bank.com`, a fraud alert from `alerts@e.bank.com`, a marketing message you did not really ask for, and—indistinguishable at a glance—a message from “Bank Security Team” `<security@bank-support-online.com>` urging you to confirm your login. The first three you wanted. The last is a phishing attempt. Every one of them arrived the same way: someone typed your address and pressed send.

cs-mail already changed that story for strangers. An unknown person must post a refundable bond to reach you, and you accept or reject the relationship. But your bank is neither a stranger you want to charge nor a person you “accept” as a standing contact. You chose to hear from it, for particular reasons, and it will write to you from many addresses for years. The two states *cs-mail* already has—bonded stranger and accepted person—do not fit it. That gap is what this memo is about.

2 The Problem: Two Kinds of Wanted Mail

Wanted mail comes in two shapes. The first is people and ongoing relationships: a colleague, a friend, a new client. *cs-mail* handles these by acceptance— you grant a person standing permission and they write freely thereafter. The second is organizations you have authorized for a bounded purpose: the bank’s statements, the airline’s boarding pass, the pharmacy’s refill notice, the clinic’s appointment reminder. Call this *transactional mail*.

Transactional mail does not fit acceptance, for four reasons:

- It arrives from many addresses. One bank sends from `statements@`, `alerts@`, and `no-reply@e.bank.com`. Accepting an address would mean accepting dozens, and missing the next one.
- It arrives at volume and without your reply. You will never hand-curate it.
- It is narrow. You want the bank’s fraud alerts; you did not necessarily invite its marketing.

- The sender usually is not on *cs-mail* yet. Your bank still sends ordinary email, and will for a long time.

So we need a third permission state: a way to grant a chosen organization a bounded, revocable, effortless right to reach you—one that resists impersonation and works *before* the sender adopts *cs-mail*. We call it an *express lane*. Before describing it, two pieces of background make it comprehensible.

3 What You Need to Know First

3.1 The “From” line is not identity

The sender shown on an email is like the return address handwritten on an envelope: a claim, not a proof. Anyone can write “Your Bank” as the sender name and `security@bank.com` as the address; nothing in ordinary email stops them. Phishing is precisely this move. An express lane therefore can never be granted to a display name or a typed address, because neither is evidence of who actually sent the message.

3.2 Mail can prove authorized domain use: SPF, DKIM, and DMARC

Two widely deployed standards let a receiving system check a message cryptographically, and most newcomers have never heard of them.

DKIM attaches a domain signature to a message; *SPF* authenticates the domain responsible for the SMTP sending path. Either can authenticate a domain, but that domain is not necessarily the one visible to the reader.

DMARC, standardized by RFC 9989, ties a passing SPF or DKIM identity to the visible RFC 5322 author domain through strict or relaxed alignment. It also lets a domain publish its requested handling for failures.

Together they answer one precise question: did the owner of the visible author domain authorize its use on this message? They do not say the message is friendly, wanted, legally from a particular company, or safe. A look-alike domain can pass DMARC for itself. The lane’s separate expected-domain match supplies that missing decision.

3.3 What *cs-mail* already provides

cs-mail already gives us bonded first contact for strangers and the idea of recipient-granted permission. The protocol specification also already defines a general *scoped capability*—a recipient-signed grant that lets a sender skip the bond for a bounded purpose. Express lanes are that launch capability, given the issuance, safety, and lifetime rules it needs to actually work.

4 The Solution: Express Lanes

An express lane is a recipient-granted, revocable, bond-free path for one sender you have chosen, bounded in purpose and time. Three properties make it safe.

What it limits. A lane controls *who* may reach you, *how much*, and for *how long*—not *what* they say. Because *cs-mail* content is end-to-end encrypted, no provider reads a message to confirm it is “really about your account.” “Purpose” is therefore a label, plus volume and time caps, plus your power to revoke—not content inspection. This is a deliberate limit, and an honest one.

What it binds to. For a sender already on *cs-mail*, the lane binds to the sender’s cryptographic protocol identity, and the provider can honor it without even learning which organization it is. For a legacy sender—your bank today—the lane binds to the canonical *organizational domain* established by a DMARC pass, `bank.com`, and honors a message only when its visible author domain falls under that identity. It never binds to a display name or a single address. So the same lane behaves sensibly across every case in the opening story:

- the fraud alert from `alerts@e.bank.com` and the statement from `statements@bank.com` both ride the lane, because both authentically come from `bank.com`;
- “Bank Security Team” `<security@bank-support-online.com>` does not, because its authenticated domain is not `bank.com`;
- `security@bank.com.evil.com` does not, because its authenticated domain is `evil.com`.

The phishing message from Friday fails at exactly this line.

Why it is safe to grant freely. An express lane is trust you can withdraw in one tap. If it is abused—the bank floods you, or a lane is somehow misused—you revoke it, and the sender drops back to the ordinary bonded gate, where it must pay to reach you again. Because the cost of a mistake is a single tap, you can hand out lanes liberally without building a permanent, unmanageable allowlist. A block always overrides a lane.

The three permission states now cover the whole of your inbox:

Who	How they reach you	How it is granted and ended
A stranger	Posts a refundable bond; you accept or reject.	Automatic on any first contact; settled by your decision.
A person you accept	Writes freely, no bond.	You accept the relationship; you revoke it.
An organization you chose	Travels a bond-free express lane, bounded in purpose and time.	Issued from a decision you already made; you revoke it or let it lapse.

The legacy binding is a bridge. Binding to a domain is a bridge, not the destination. The day your bank adopts *cs-mail*, its lane re-binds to the bank’s cryptographic identity, the DMARC dependency falls away, and the lane becomes fully private—the provider no longer needs to see `bank.com` to honor it. The bridge advertises its own obsolescence.

5 How You Get One: Issuance

An express lane should feel like a consequence of a decision you already made, never a settings screen you must remember to visit. Two moments cover almost everything:

1. **When you hand over your address.** Signing up, checking out, or booking—the moment you give the bank your address, the client offers, in one line, to open an express lane for it.
2. **When you write first.** Emailing the bank yourself auto-opens a return lane, since you have plainly invited a reply.

For a legacy sender the grant cannot complete on a promise; it completes on proof. When you sign up on `bank.com`, the client remembers that you were on `bank.com` and expects mail from that domain. The first message that arrives claiming to be the bank is checked with DMARC; if it authentically comes from the expected domain, the client shows a one-tap confirmation naming the *authenticated domain*—not the display name—and the lane opens. Seeding the expectation from the website you were actually on turns “which bank?” into a simple match, and lets you catch a look-alike domain at the very moment of granting.

6 How a Lane Ends: Lifetime and Renewal

A lane that lasted forever by default would rebuild the very allowlist we are trying to avoid. So lifetime is bounded, but bounded intelligently.

Anchor on activity, not the calendar. A lane’s clock is its last authenticated message, not its issue date. A lane in active use stays open on its own; one that goes quiet drifts toward expiry. This captures most of the benefit of tying a lane to an event—a single flight, say—without asking anyone to define events.

The default is a gentle re-confirm. When an inactive lane reaches the end of its window, you get a light prompt—keep the airline’s lane, or let it lapse?—rather than silent deletion. You set the window per sender.

The exception that matters. Some lanes should effectively never lapse. Your bank’s fraud alerts and your hospital’s test results are exactly the mail whose silent disappearance is most costly: a lapsed lane there means a missed fraud warning or a missed result, quietly rerouted to the bonded gate. For these you choose a *persistent* lane: activity renews its ordinary horizon, and an inactive horizon produces a review reminder instead of a lapse. Even a persistent lane has a recipient-signed hard validity bound, after which a fresh grant is required.

Revocation and blocking remain available and immediate, whatever the lifetime.

7 Implementation Constraints

Three constraints shape any implementation. Their details belong in a later specification; the constraints themselves are worth stating now because they are what make the concept real.

Lanes live at the recipient’s provider. Only the provider sees inbound mail and runs the DMARC check, and the provider is already where an incoming message is either admitted or sent to the bonded gate. The lane must be evaluated there. A device cannot verify a domain on mail it never handled.

The list of lanes is sensitive and must be compartmentalized. Which organizations a person trusts, and for what—their bank, their hospital, their lawyer—is precisely the relationship profile that *cs-mail*’s privacy model exists to protect. Lanes must therefore live in the relationship privacy domain, under their own keys and access role, not in a general table that a ledger or telemetry breach could read. For senders on *cs-mail*, a lane can be a recipient-signed, pairwise-scoped grant that the provider verifies without learning the organization at all; for legacy senders the provider

must see the domain to match DMARC, which is one more reason the native path is the more private destination.

This promotes an existing feature rather than inventing settlement. The protocol specification already defines scoped capabilities, already requires that a capability-authorized message open no relationship solicitation and advance no repeated-attempt state, and already lets a block override a capability. Express lanes adopt those rules unchanged. The launch extension adds the issuance flow (the two moments and the DMARC-confirmed legacy grant), the domain-binding and expected-domain mismatch rules, and the activity-anchored lifetime with its persistent option. This changes no settlement or privacy meaning.

8 Where This Leaves *cs-mail*

With express lanes, the permission model reads as one sentence: strangers post a refundable bond to reach you, people you accept may write freely, and organizations you have chosen travel an express lane you can close at any time. Each state matches how the relationship actually feels—a stranger earning a first hearing, a person you know, an institution you deliberately signed up with. That is what mindful email means: not an inbox that guesses what you want, but one where reaching you is a permission you granted, on purpose, and can always take back.